Broken Authentication

Authentication is a fundamental pillar of web API security. Web APIs utilize various authentication mecha
confidentiality. An API suffers from `Broken Authentication` if any of its authentication mechanisms can b

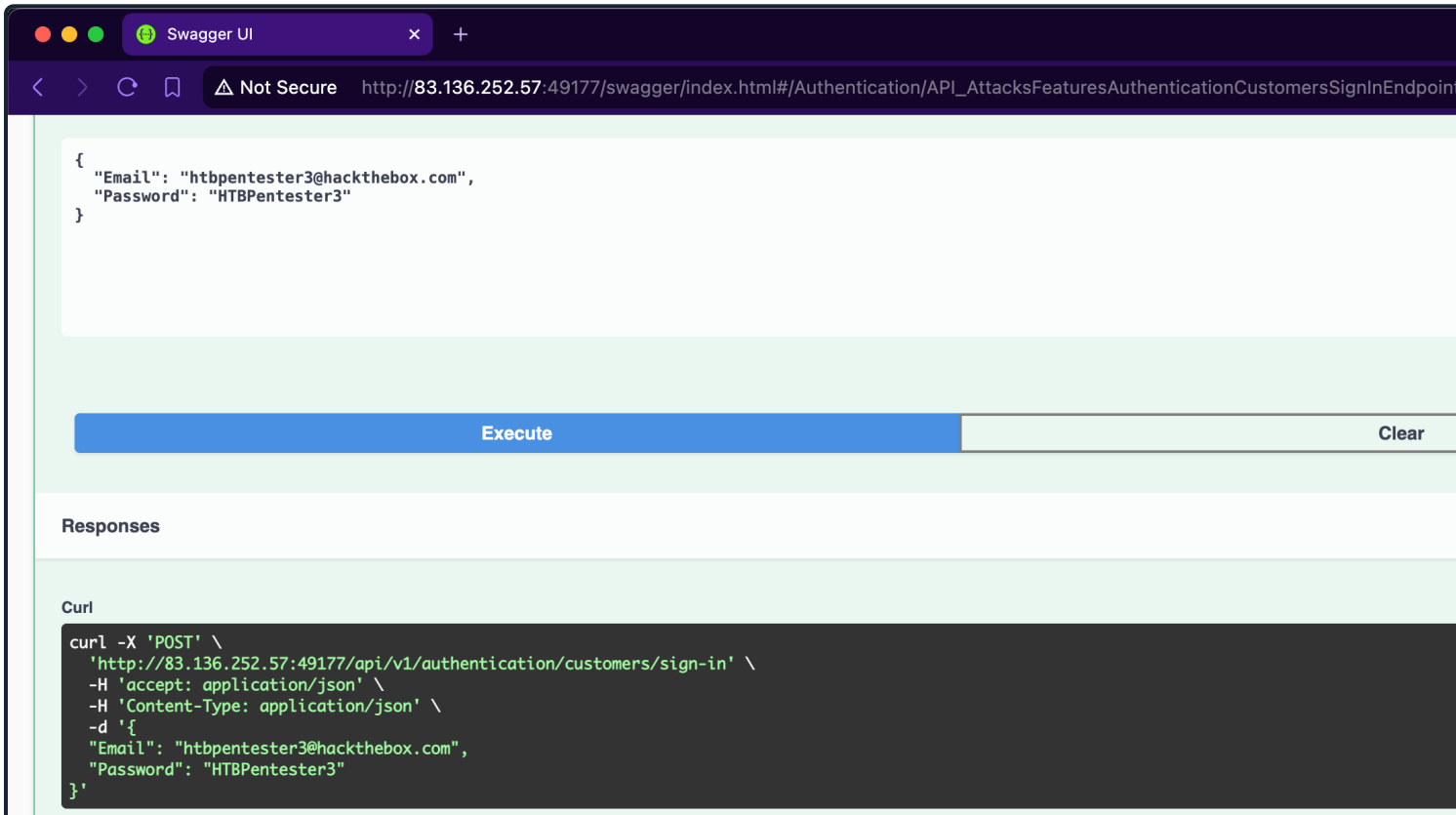
Improper Restriction of Excessive Authentication Attempts

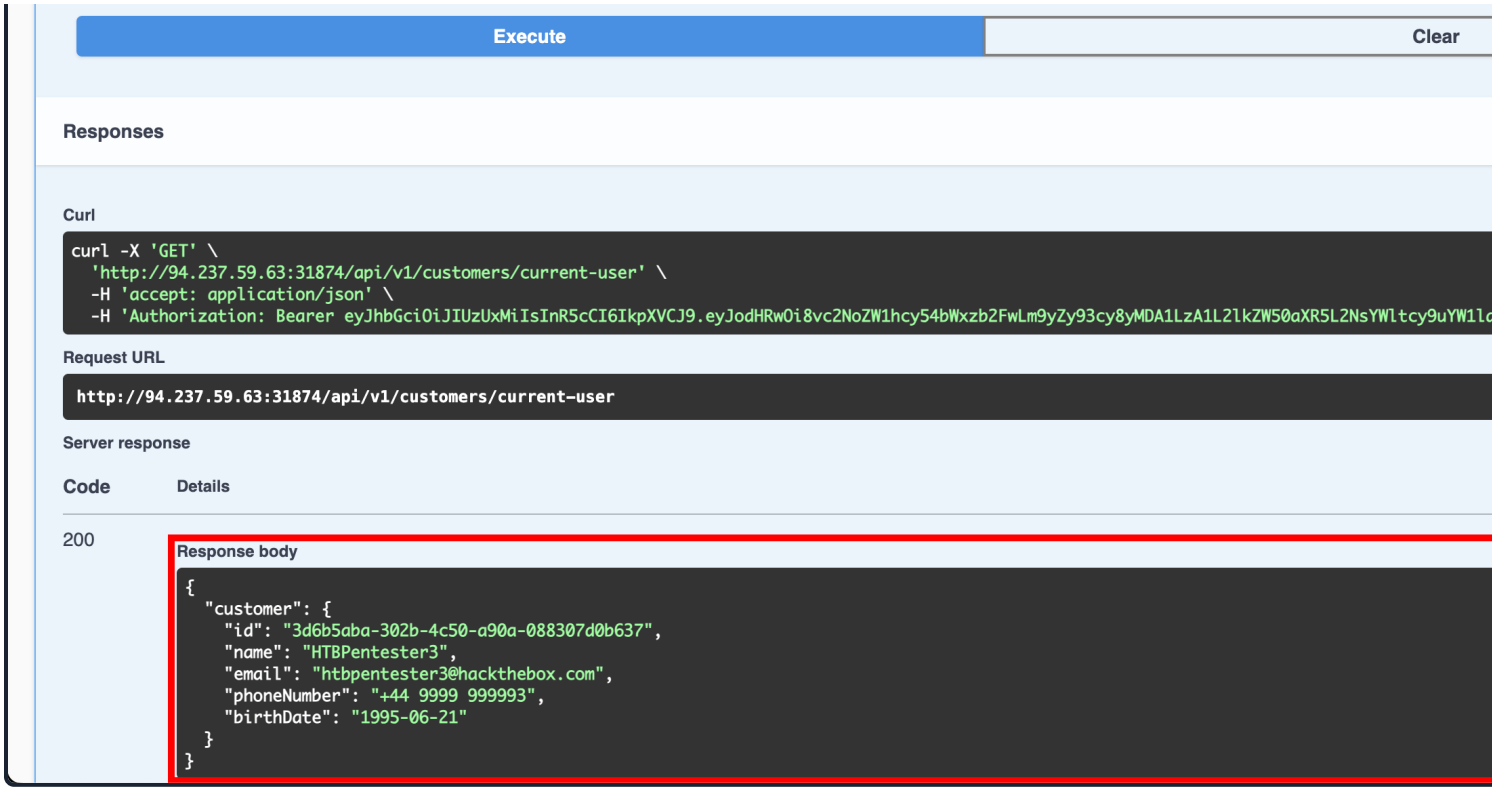
The endpoint we will be practicing against is vulnerable to CWE-307: Improper Restriction of Excessive A

Scenario

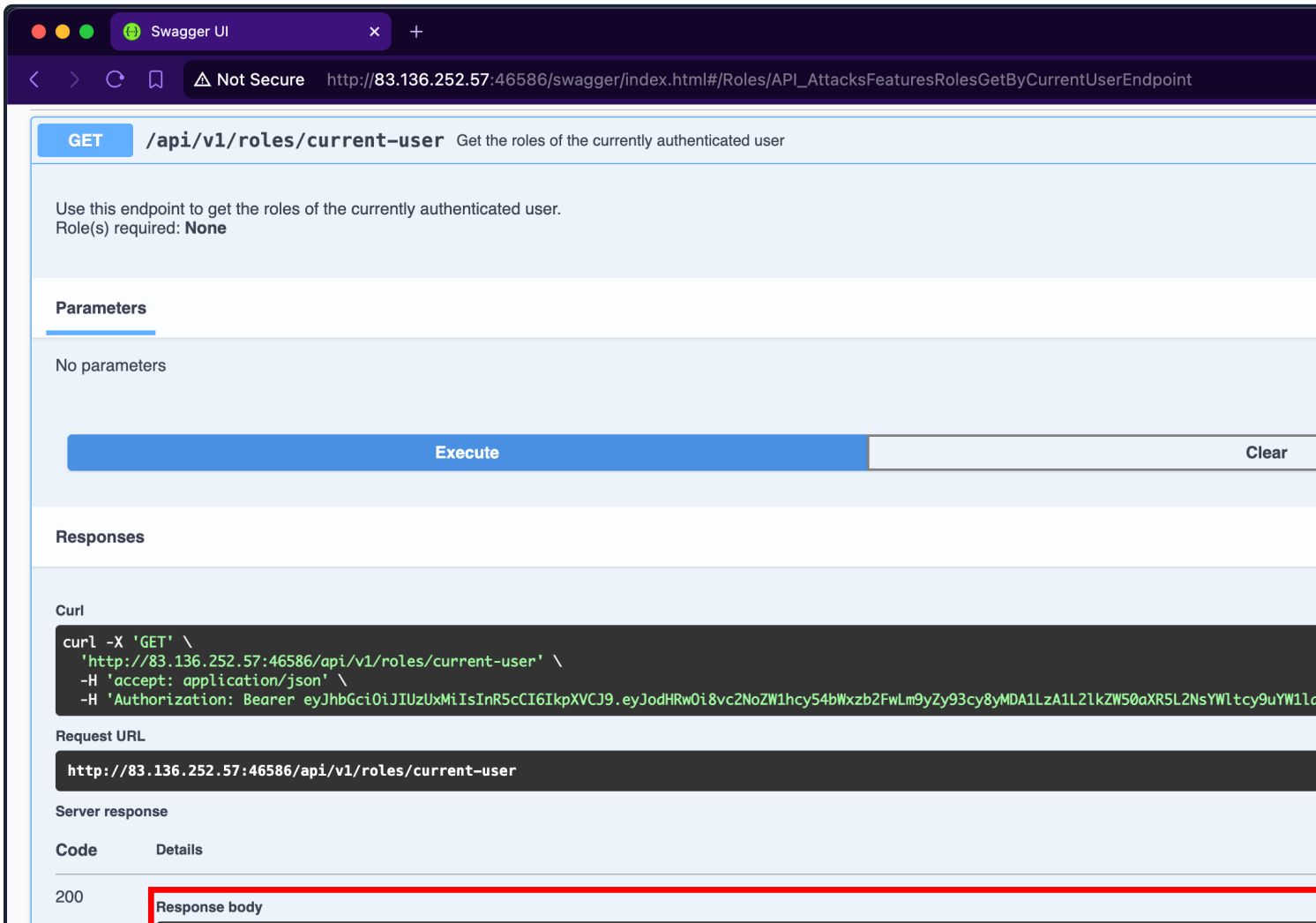
The admin of `Inlanefreight E-Commerce Marketplace` has provided us with the credentials `htbpentester3@hackthebox.com:HTBPentester3`, wanting us to assess what API vulnerabilities can the u
roles.

Because the account belongs to a supplier, we will utilize the `/api/v1/authentication/customers/sign` and then authenticate with it:





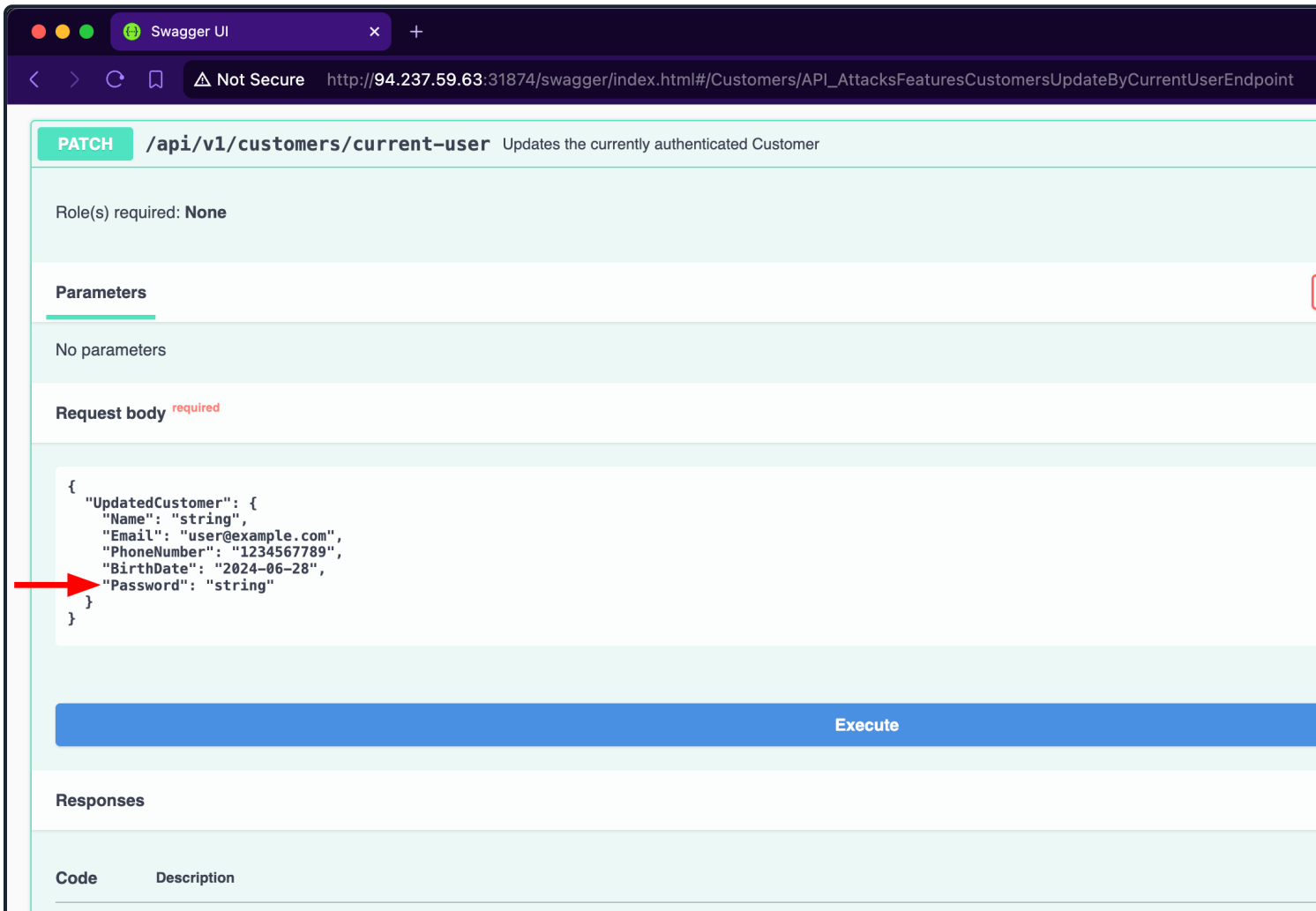
The `/api/v1/roles/current-user` endpoint reveals that the user is assigned three roles: `Customers_Upd` `Customers_Get`, and `Customers_GetAll`:



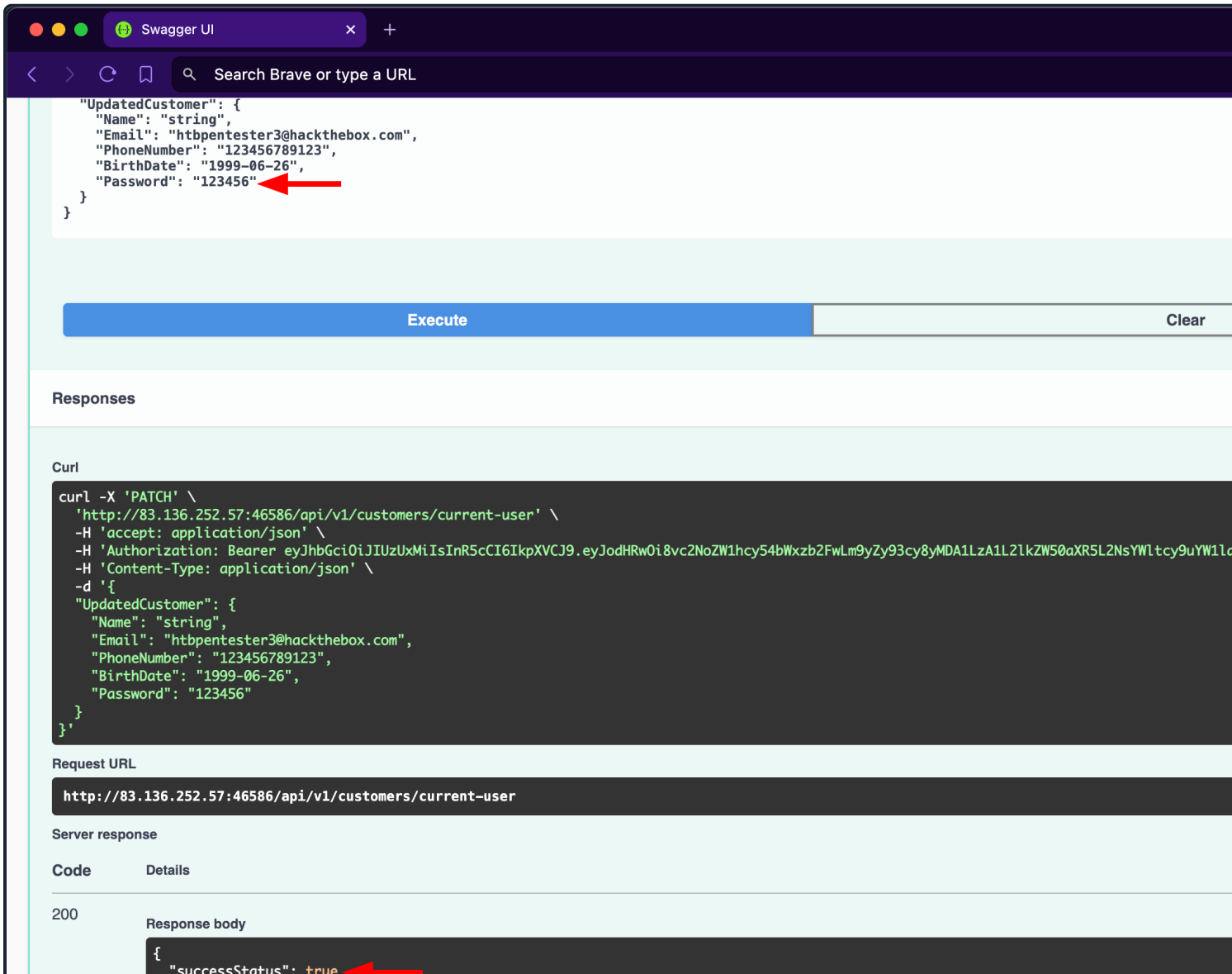
```
{
  "customers": [
    {
      "id": "fe4a4b39-3df6-425a-9525-a7b2914f711b",
      "name": "Mason Crawford",
      "email": "MasonCrawford@tuta.com",
      "phoneNumber": "+27 23 175 3261",
      "birthDate": "1963-10-06"
    },
    {
      "id": "9076351f-e6b8-4445-84e3-72800c79dd1d",
      "name": "Elijah Tucker",
      "email": "ElijahTucker@gmx.com",
      "phoneNumber": "+44 2999 733596",
      "birthDate": "1963-04-09"
    },
    {
      "id": "3589e7f7-2d8a-4873-8bd9-b2c20b7a0ad2",
      "name": "Victoria Munoz",
      "email": "VictoriaMunoz@live.com",
      "phoneNumber": "(167) 487-3818",
      "birthDate": "1974-05-06"
    },
    {
      "id": "a0683cc9-a71f-4957-8fbb-45ead732040e"
```


Although the endpoint suffers from `Broken Object Property Level Authorization` (which we will cove because it exposes sensitive information about other customers, such as `email`, `phoneNumber`, and `birth` to hijack any other account.

When we expand the `/api/v1/customers/current-user PATCH` endpoint, we discover that it allows us to including the account's password:



The validation message provides valuable information, exposing that the API uses a weak password polic cryptographically secure passwords. If we try setting the password to '123456', we will notice the API now status, indicating that it performed the update:



Instead of attacking all 107 customers, the admin of `Inlanefreight E-Commerce Marketplace` has provi high-value targets (which we need to save in a file):

- `OlawaleJones@yandex.com`
- `IsabellaRichardson@gmail.com`
- `WenSalazar@zoho.com`

For the password wordlist, we will use xato-net-10-million-passwords-10000 from SecLists.

Because we are fuzzing two parameters at the same time (which are the email and password), we need to assign the keywords `EMAIL` and `PASS` to the customer emails and passwords wordlists, respectively. Once that the password of `IsabellaRichardson@gmail.com` is `qwerasdfzxcv`:

Broken Authentication

```
dbcyph0n@htb[/htb]$ ffuf -w /opt/useful/seclists/Passwords/xato-net-10-million-passwor

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
________________________________________________

 :: Method           : POST
```

`Inlanefreight E-Commerce Marketplace`.

Brute-forcing OTPs and Answers of Security Questions

Applications allow users to reset their passwords by requesting a `One Time Password` (`OTP`) sent to a devi
security question they have chosen during registration. If brute-forcing passwords is infeasible due to str
attempt to brute-force OTPs or answers to security questions, given that they have low entropy or can be
limiting not being implemented).

Prevention

To mitigate the `Broken Authentication` vulnerability, the `/api/v1/authentication/customers/sign-in`
rate-limiting to prevent brute-force attacks. This can be achieved by limiting the number of login attempts
account within a specified time frame.

Moreover, the web API should enforce a robust password policy for user credentials (including customers
registration and updates, allowing only cryptographically secure passwords. This policy should include:

1. `Minimum password length` (e.g., at least 12 characters)
2. `Complexity requirements` (e.g., a mix of uppercase and lowercase letters, numbers
3. `Prohibition of commonly used or easily guessable passwords` (such as ones found in
4. `Enforcement of password history to prevent reuse of recent passwords`
5. `Regular password expiration and mandatory changes`

Additionally, the web API endpoint should implement multi-factor authentication (`MFA`) for added security,
authenticating users.

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 83.136.255.40:46305

Life Left: 52 minute(s)

+ 1 Exploit another Broken Authentication vulnerability to gain unauthorized access to the customer 'MasonJenkins@ymail.com'. Retrieve their payment options data and submit the flag.

Submit your answer here...

+10 Streak pts Submit

Previous Next

? Go to Questions

Table of Contents

My Workstation

OFFLINE

Start Instance

∞ / 1 spawns left